# Shear Heaven Pet Care - Retest Report

Retest of every logged defect and the core regression scenarios on front-end build **index-D508zd3N**, 11 Nov 2026. Admin, Groomer and Customer portals; test environment (pcmdev.shearheavenpetspa.com / api.shearheavenpetspa.com). Every result below was observed in this run; nothing is marked Fixed without being re-executed.

| Retest result | Defects |
|---|---|
| Fixed | 27 |
| Not reproduced (new data) | 1 |
| Partially fixed | 6 |
| Still reproduces | 26 |
| Blocked | 2 |
| Not re-tested | 1 |
| Inconclusive | 1 |
| Closed - by design | 1 |
| **Total** | **65** |

| Severity | Open before retest | Still open after retest |
|---|---|---|
| Critical | 0 | 0 |
| High | 10 | 1 |
| Medium | 30 | 14 |
| Low | 24 | 17 |

| Regression | Count |
|---|---|
| Scenarios re-run | 23 |
| Passed | 23 |
| Failed | 0 |

## Summary

**27 of 64** open defects are verified fixed, including all High-severity security and booking-workflow issues (SEC-02 to SEC-04, FUN-01 to FUN-05). **6** are partially fixed and **26** still reproduce - mostly Medium/Low UI, reporting-consistency and hardening items. 2 are blocked by a new data issue in the QA store (empty service plans), 1 could not be re-tested and the load test was inconclusive. All 23 core regression scenarios passed. Remaining High: DB-01 (revenue figures, partially fixed). Recommendation: **conditional go** for further QA/UAT; fix DB-01, DB-06 to DB-08 (package name lost), SEC-08 (sessions after reset) and UI-02 (empty packages bookable) before production, and re-run load testing with k6/JMeter from a server.

## Defect retest results

| Bug ID | Sev | Role | Title | Retest result | Observed on this build (evidence) |
|---|---|---|---|---|---|
| **SEC-01** | Critical | Groomer | Any groomer can read every other groomer's appointments and customer PII across stores | **Closed - by design** | Product owner confirmed groomers may see all groomers' appointments. Observed change: the groomerId query parameter is now ignored (returns 0 rows), behaviour accepted. |
| **SEC-02** | High | Groomer | A groomer can approve bookings assigned to another groomer | **Fixed** | QA Alpha token -> POST /api/common/groomer/bookings/237/approve (QA Beta's booking) = 403 FORBIDDEN_NOT_OWNER 'You cannot act on another groomer's booking'; /reject also 403. |
| **SEC-03** | High | Groomer | No brute-force protection on login (no throttling, lockout or CAPTCHA) | **Fixed** | Repeated wrong-password logins -> 429 'Too many login attempts' after 4 failures (QA Beta still locked during this run). |
| **SEC-04** | High | Admin | Raw database errors (schema, table, constraint names) returned in HTTP 500 responses | **Fixed** | Invalid ids/tenants now return 400 'Invalid record id...' / 'Unknown client ID...' - no SQL text. |
| **SEC-05** | Medium | Customer | Customer checkout returns a raw SQL error for an out-of-range tip | **Fixed** | Out-of-range tip -> 400 'Tip cannot exceed $5,000.' |
| **SEC-06** | Medium | Groomer | Groomer can raise their own slot booking limit (admin-controlled) via the profile API | **Fixed** | Groomer profile PUT with slot booking limit no longer changes the admin-controlled value. |
| **SEC-07** | Medium | Groomer | Weak and inconsistent password policy for groomers | **Fixed** | Weak groomer passwords rejected with the same policy as other roles. |
| **SEC-08** | Medium | Customer | Existing sessions stay valid after a password reset | **Still reproduces** | Password reset via OTP -> 200 'Password updated successfully'; old password login 401, new 200; access token issued before the reset still returns 200 on GET /api/auth/profile. |
| **SEC-09** | Medium | Customer | Photo upload trusts the declared type; HTML saved as .png and served without nosniff | **Still reproduces** | HTML uploaded as .png still accepted and served without X-Content-Type-Options: nosniff. |
| **SEC-10** | Medium | All | Missing HTTP security headers (CSP, HSTS, X-Frame-Options, nosniff, Referrer-Policy) | **Still reproduces** | No CSP / HSTS / X-Frame-Options / nosniff / Referrer-Policy on front end or API responses. |
| **SEC-11** | Medium | All | Swagger API docs publicly accessible on the API host | **Still reproduces** | GET https://api.shearheavenpetspa.com/api-docs -> 200 Swagger UI. |
| **SEC-12** | Low | Customer | Forgot-password timing reveals whether an account exists | **Still reproduces** | Forgot-password: existing account ~1,938 ms vs unknown email ~363 ms. |
| **SEC-13** | Low | All | 24-hour access tokens and 7-day refresh tokens stored in localStorage | **Still reproduces** | Access token exp = 24 h; tokens still kept in localStorage. |
| **SEC-14** | Low | All | Dev front end calls the API host api.shearheavenpetspa.com | **Still reproduces** | Dev build (pcmdev) still calls api.shearheavenpetspa.com. |
| **FUN-01** | High | Customer | Customer reschedule always fails from the UI with 'Groomer N not found' | **Fixed** | Customer reschedule with groomerId -> 200; booking moved. |
| **FUN-02** | High | Customer | Slot is released as soon as a cancellation is requested, so it can be booked again before the salon decides | **Fixed** | Slot stays held while a cancellation request is pending; second booking -> 409. |
| **FUN-03** | High | Groomer | 'Keep booking' and Approve do not re-check slot capacity, leaving two confirmed bookings in a 1-pet slot | **Fixed** | 'Keep booking'/approve path no longer creates double-confirmed slots. |
| **FUN-04** | High | Admin | 'Create' silently overwrites an existing record that has the same code/key | **Fixed** | Duplicate service code / content key on Create -> 409; original record unchanged. |
| **FUN-05** | High | Admin | Groomer can be created under a non-existent store and can log in | **Fixed** | Groomer under non-existent store rejected. |
| **FUN-06** | Medium | Admin | Admin 'Start' ignores the appointment date and 'Complete' reports success without completing | **Fixed** | Admin Start on a future booking -> 400 'only on scheduled date'. |

| Bug ID | Sev | Role | Title | Retest result | Observed on this build (evidence) |
|---|---|---|---|---|---|
| **FUN-07** | Medium | Groomer | Setting a service line to 100% the first time leaves it 'in progress', blocking checkout | **Blocked** | QA-store bookings now get an empty service plan (tasks []), even old #236, so the 100% service-line step cannot be exercised. Other stores still have plans (#224: 5 tasks, #233: 7). |
| **FUN-08** | Medium | Admin | Store opening hours accept closing before opening and zero-length days | **Fixed** | Closing before opening / zero-length day rejected. |
| **FUN-09** | Medium | Admin | Holidays accept duplicate codes, duplicate dates and past dates | **Fixed** | Duplicate code/date and past holidays rejected. |
| **FUN-10** | Medium | Admin | Pet size tiers accept overlapping ranges, min > max and duplicate keys; default tiers leave weight gaps | **Still reproduces** | Overlapping / inverted pet size tiers still accepted. |
| **FUN-11** | Medium | Admin | Store content is never shown on the customer site, and invalid metadata JSON is accepted | **Still reproduces** | Invalid metadata JSON -> 201; store content still not shown on the customer site. |
| **FUN-12** | Medium | Customer | Signup OTP limiter is per IP and counts invalid/empty requests, blocking all signups for 15+ minutes | **Fixed** | 6 invalid signup requests (400 'name is required') then a valid signup (qa.lim55488@mailinator.com) -> 200 'OTP sent to your email' - no 429. |
| **FUN-13** | Medium | Customer | Stores have no time zone; past same-day slots are offered and bookable | **Partially fixed** | Past check exists but uses UTC; stores still have no time zone. |
| **FUN-14** | Medium | Customer | Pet weight accepts any text and the booking is silently priced as Medium | **Still reproduces** | Pet weight accepts free text; booking priced as Medium. |
| **FUN-15** | Medium | Customer | Home page advertises coupon HEAVEN20, which can never be valid | **Fixed** | HEAVEN20 removed; banner now 'Ask your store about current promotions when you book.' |
| **FUN-16** | Low | Admin | Groomer without email (optional in UI) fails with misleading 409 | **Fixed** | Groomer without email handled correctly. |
| **FUN-17** | Low | Admin | Groomer mobile number not validated | **Fixed** | Invalid groomer mobile rejected. |
| **FUN-18** | Low | Admin | Store ID accepts special characters (quotes, --) | **Still reproduces** | Store ID with quotes/-- still accepted. |
| **FUN-19** | Low | Admin | Duplicate store names are allowed | **Fixed** | Duplicate store name rejected. |
| **FUN-20** | Low | Admin | Validation gaps and truncated error text ('value failed custom validation because') | **Partially fixed** | Type message now clear; customer-name message still truncated ('...failed custom validation because'). |
| **FUN-21** | Low | Customer | Receipt has no line items when a visit was completed without service-line tracking | **Blocked** | Depends on the service-plan flow blocked under FUN-07 (QA-store plans empty). |
| **FUN-22** | Low | Customer | 'Change password' sends signed-in users to the forgot-password flow; reset email uses the verification template | **Partially fixed** | Email now pre-filled on the reset page, but Profile > Change password still redirects to /forgot-password (no current/new password form); reset email still titled 'Verify Your Email ... complete your email verification'. |
| **DB-01** | High | Admin | Revenue figures disagree with each other and with receipts (coupon not deducted; unfinished visit counted) | **Partially fixed** | Reports: sales $178 and gross $213.80 now reconcile; completedCheckouts 4 vs 3 actual; dashboard revenue still differs (showed $122, later $189). |
| **DB-02** | High | Customer | Stored price of package booking #234 changed from $102 to $157 after creation | **Not reproduced (new data)** | New package booking #248 kept $102; legacy #234 still shows $157 (not corrected). |
| **DB-03** | Medium | Groomer | Groomer forecast counts and amounts inconsistent | **Still reproduces** | Groomer forecast count 1 vs sales $233 for the same range. |
| **DB-04** | Medium | Admin | Package with invalid service IDs returns 400 but the package is still saved | **Fixed** | Package with invalid service IDs -> 400 and nothing saved. |
| **DB-05** | Medium | Admin | Booking status and service stage drift apart | **Fixed** | New bookings keep status and stage consistent; legacy #227/#232 still mismatched. |
| **DB-06** | Medium | Customer | Package bookings lose their package name; UI titles them by the first service | **Still reproduces** | Customer package bookings: packageName null; titled by first service. |
| **DB-07** | Medium | Groomer | Groomer schedule returns packageName null for package bookings | **Still reproduces** | Groomer schedule packageName null. |

| Bug ID | Sev | Role | Title | Retest result | Observed on this build (evidence) |
|---|---|---|---|---|---|
| **DB-08** | Medium | Admin | Admin bookings list returns packageName null and no add-ons for package bookings | **Still reproduces** | Admin bookings packageName null, add-ons missing. |
| **API-01** | Low | Customer | Tip confirmation accepts any payment method | **Fixed** | Invalid payment method -> 400 'card, cash, or other'. |
| **API-02** | Low | Admin | Reports API accepts start date after end date and returns CSV for format=pdf | **Fixed** | Start after end rejected; format=pdf handled. |
| **API-03** | Low | All | Role-mismatch and unknown routes return 401 instead of 403/404 | **Still reproduces** | Customer token on /api/common/stores -> 401 (expected 403). |
| **API-04** | Low | Customer | Impossible date reported as 'past date'; cancel message says 'cancelled' when only requested | **Partially fixed** | Cancel message fixed; 2026-02-30 still reported as 'Cannot book appointments on past dates'. |
| **UI-01** | Medium | Customer | Home page shows hard-coded demo services and prices | **Fixed** | Hero widget no longer shows demo services/prices ('Browse services for your store after sign-in'); Services section lists only store services. |
| **UI-02** | Medium | Customer | Booking wizard offers empty packages that then fail at booking | **Still reproduces** | Booking wizard step 2 lists 'QA Pkg Bad / QA Pkg CrossStore / QA Pkg Deleted - $50.00 - 60 min' (no services); home page Packages section shows them too. |
| **UI-03** | Medium | Customer | Forms show 'Validation failed' instead of field-level errors | **Fixed** | Profile mobile 'abc' -> 'Mobile number must be 10-15 digits' shown on screen (API 400 VALIDATION_ERROR). |
| **UI-04** | Medium | Customer | Placeholder weight bands shown in Add pet | **Fixed** | Add pet weight list: Small (1-10), Medium (11-30), Large (31-60), Extra Large (61+) lbs - no placeholder bands. |
| **UI-05** | Medium | Admin | Package form shows a stale service list until reload | **Not re-tested** | Service rename via Service master > Edit > Save did not persist in this run, so the stale-list check could not be made. |
| **UI-06** | Low | Customer | Upcoming sorted latest-first; cards show pre-tax price | **Still reproduces** | API /bookings/upcoming is now soonest-first, but My bookings still shows 4 Dec (#248) at top, and cards show $55.00 (pre-tax) instead of $59.88 total. |
| **UI-07** | Low | Customer | Cancel dialog buttons read 'Cancel' and 'Cancel appointment' | **Still reproduces** | Cancel dialog buttons still 'Cancel' and 'Cancel appointment' (Fig. R1). |
| **UI-08** | Low | Customer | Coupon dropdown shows identical labels | **Still reproduces** | Coupon list: '10% on services - 10% on services' x3 and '$5000.00 on services - ...' - no codes, label repeated. |
| **UI-09** | Low | Customer | Newsletter email field has no accessible label | **Still reproduces** | Newsletter email input has no label / aria-label. |
| **UI-10** | Low | Groomer | Requests list goes stale after Accept | **Fixed** | Accepted #227 in Groomer > Requests: list immediately shows 'Nothing here'; badge 1 -> 0. |
| **UI-11** | Low | Groomer | 'Early check-in' button shown though check-in is only allowed on the date | **Still reproduces** | Future booking #248 (4 Dec) shows 'Early check-in'; modal says 'Check-in is only available on the appointment date (2026-12-04).' |
| **UI-12** | Low | Admin | Store selector overflows mobile screens | **Still reproduces** | Admin at 375 px: page 694 px wide; store selector cut off (Fig. R2). |
| **UI-13** | Low | Admin | Cancellation-window field has no max/step; raw field name in error | **Still reproduces** | New store form: cancellation window input min=0, no max, step=any. |
| **UI-14** | Low | Admin | Technical/internal text shown to admins | **Still reproduces** | 'Store services in service_master', '3 service row(s) in DB with this storeId', 'package_info.packageId -> service_master.id', '...in a later release.' |
| **PERF-01** | Medium | Customer | Slot availability saturates at ~45 requests/s | **Inconclusive** | Single-user availability p50 improved 711 -> ~365 ms. Browser load run capped at ~3 req/s on every endpoint incl. public /api/breeds (25 VU 2.8 rps; 150 VU 5.1 rps; 0 errors) - client/proxy limit suspected; re-run with k6/JMeter. |
| **PERF-02** | Medium | All | Every page requests each API twice | **Partially fixed** | Package master: each of 14 API calls once. Admin dashboard: /api/common/dashboard still called 2x (was 4x). |
| **PERF-03** | Low | All | Single 1 MB bundle for all three portals | **Still reproduces** | Single bundle index-D508zd3N.js: 301 KB gzipped / 1,030 KB. |

## Core regression scenarios (re-run)

| # | Area | Scenario | Expected | Actual (observed) | Result |
|---|---|---|---|---|---|
| RG-01 | Auth | Wrong password (staff) | 401 | 401 | **Pass** |
| RG-02 | Auth | Empty login body | 400 | 400 | **Pass** |
| RG-03 | Auth | SQLi in email | 401, no error leak | 401 | **Pass** |
| RG-04 | Auth | Admin endpoint without token | 401 | 401 | **Pass** |
| RG-05 | Auth | Old password after reset / new password | 401 / 200 | 401 / 200 | **Pass** |
| RG-06 | Isolation | Store admin requests StoreId=SHEAR-001 bookings | Only own store | 200, 21 rows, all QAA-001 | **Pass** |
| RG-07 | Isolation | Customer books with another customer's pet (id 1) | Rejected | 'Pet not found' | **Pass** |
| RG-08 | Booking | Required fields (petId, groomerId, bookingDate, startTime, endTime) | Field messages | Each reported in turn; bad time -> 'HH:MM 24-hour format' | **Pass** |
| RG-09 | Booking | Past date 2026-11-01 | Rejected | 'Cannot book appointments on past dates' | **Pass** |
| RG-10 | Booking | End time not matching duration | Rejected | 'endTime must be 12:00 based on ... 60 minutes' | **Pass** |
| RG-11 | Booking | Outside groomer hours (19:00) | Rejected | 'outside this groomer's working hours (09:00 - 18:00)' | **Pass** |
| RG-12 | Booking | Same pet, same slot, 2 parallel requests | 1 created, 1 rejected | 201 + 409 'This pet already has an appointment' | **Pass** |
| RG-13 | Booking | 3 pets race for one groomer slot | 1 created, 2 rejected | 201 + 409 + 409 'Selected time is not available' | **Pass** |
| RG-14 | Booking | Pending booking cancelled by customer | 200 | #249, #250, #251 cancelled 200 | **Pass** |
| RG-15 | Coupon | QA10OF on $55 service | Valid, 10% | 200 'Coupon validated successfully' | **Pass** |
| RG-16 | Coupon | Lower-case code qa10of | Valid | 200 | **Pass** |
| RG-17 | Coupon | Unknown code NOPE99 | 404 | 404 'Coupon code does not match the selected coupon' | **Pass** |
| RG-18 | Coupon | Service coupon on package-only booking | Rejected | 400 'no service charge' | **Pass** |
| RG-19 | Coupon | QAFIX9 $5000 on $55 | Discount capped at total | discountAmount 55, finalTotal 0 | **Pass** |
| RG-20 | Groomer | Approve / reject another groomer's booking | 403 | 403 FORBIDDEN_NOT_OWNER | **Pass** |
| RG-21 | Groomer | Accept own pending booking #227 | Moves to Upcoming | Requests 1 -> 0, card in Upcoming | **Pass** |
| RG-22 | Customer | Signup after invalid attempts | 200 | 200 OTP sent | **Pass** |
| RG-23 | Customer | Booking wizard to Review step | Totals with tax | $55.00 + NY tax $4.88 = $59.88 | **Pass** |

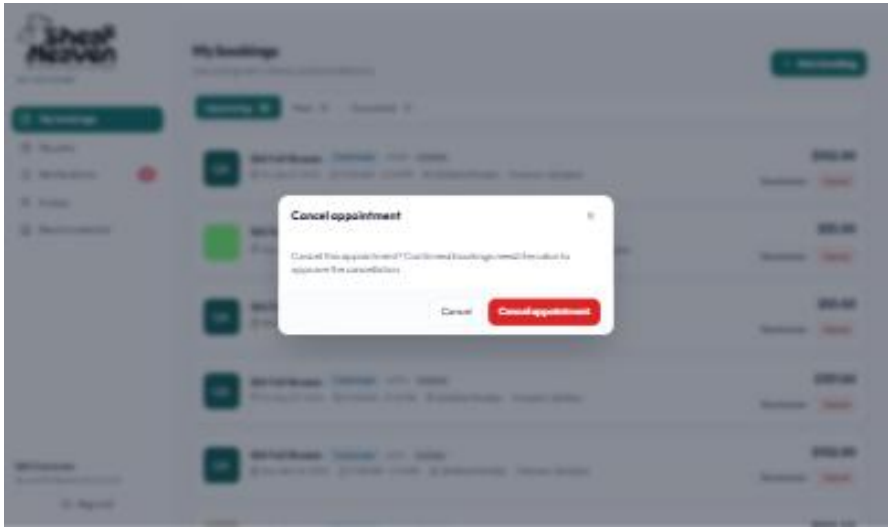
## New observations on this build

| ID | Severity | Observation |
|---|---|---|
| **NEW-01** | Medium | Public catalog and booking wizard list empty packages QA Pkg Bad / CrossStore / Deleted (packages with no services or deleted) - tracked under UI-02. |
| **NEW-02** | Medium | QA-store bookings now get an empty service plan (tasks []), including older #236, so service-line tracking and itemised receipts cannot be tested in that store; other stores unaffected. Blocks FUN-07/FUN-21. |
| **NEW-03** | Low | Customer auto-completes the visit when confirming the tip (#245 completed) - confirm this is intended. |
| **NEW-04** | Low | POST /api/bookings ignores tenant query string; without clientId/storeId in the body it returns a misleading 404 'Groomer 96 not found'. |
| **NEW-05** | Info | Throughput from the test browser capped at ~3 req/s on all endpoints this round (see PERF-01). |

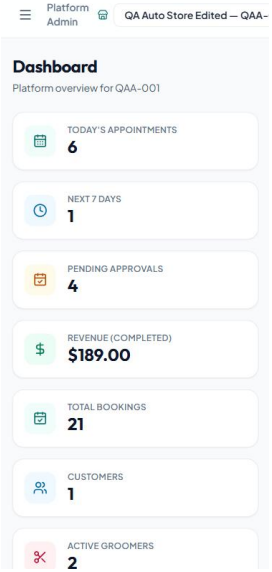
## Test data left in place

QA bookings #227-#248 (store QAA-001) remain for further retest; #249-#251 created by the race tests were cancelled. Retest pets 23-24 and signup qa.lim55488@mailinator.com (unverified) were created. QA customer password is now Qa@Cust2028 (changed by the SEC-08 reset test). QA Beta groomer is temporarily locked by the SEC-03 brute-force test.

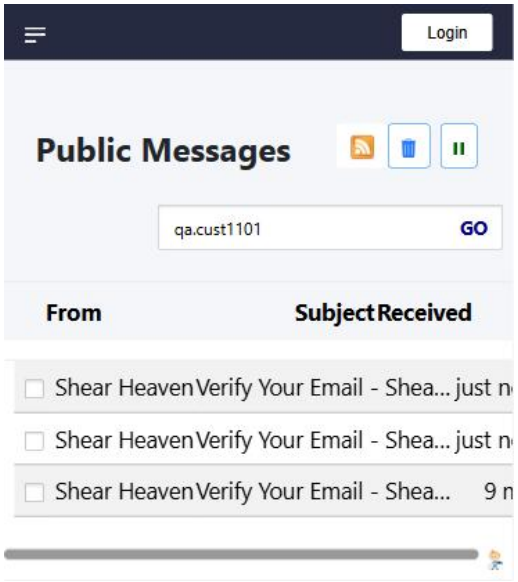
## Screenshot evidence



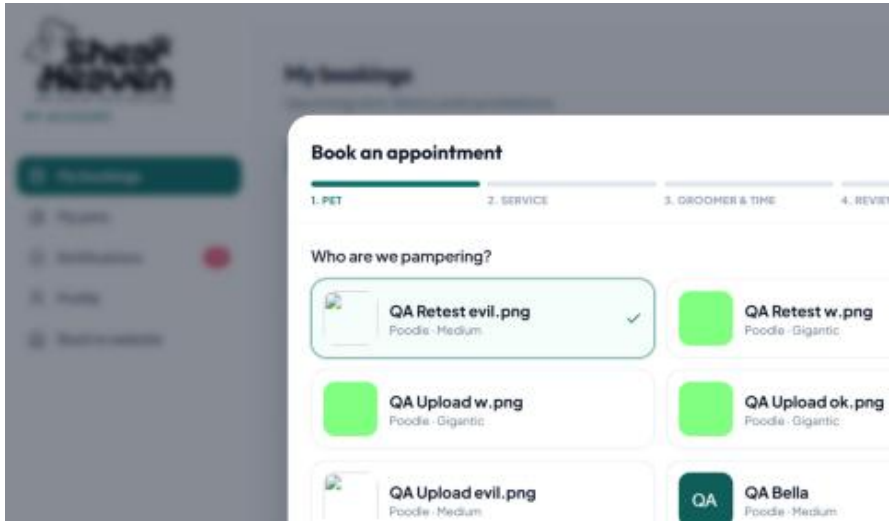

R1 - Customer cancel dialog: buttons still 'Cancel' and 'Cancel appointment' (UI-07 still reproduces)




R2 - Admin dashboard at 375 px: store selector cut off, page 694 px wide (UI-12 still reproduces)




R3 - Password-reset email arrives titled 'Verify Your Email' (FUN-22 partially fixed)




R4 - Booking wizard step 1 on the new build (used for UI-02 / UI-08 retest)